

LDAP-инъекция

Описание проблемы

Инъекция в LDAP-запрос - это уязвимость, которая возникает из-за того, что входные данные не валидируются, и после этого попадают в функции/методы, выполняющие LDAP-запрос. По сути, благодаря такой уязвимости, злоумышленник может выполнить абсолютно произвольный запрос к службе каталогов.

При формировании LDAP-запроса есть два места, куда злоумышленник может сделать инъекцию:

1. Distinguished name (dn) - расположение в каталоге, куда выполняется запрос.
2. Фильтр - сам запрос.

В Python выполнить LDAP-запрос можно с помощью `ldap.initialize.search_s`

Последствия эксплуатации

Атакующий может получить возможность читать и модифицировать любую информацию из LDAP-дерева. А поскольку LDAP чаще всего используется для аутентификации, эти данные являются критичными. Например, можно изменить записи таким образом, что ни один пользователь не сможет залогиниться в приложение.

Пример небезопасного кода

```
1 dn = params.Get['dn']
2 jediTypeRequest = params.Get['jediType']
3
4 ldapQuery = f"(|(jediType={jediTypeRequest})(&(cloneWars=yes)
  (alive=yes)))"
5
6 connection = ldap.initialize("ldap://127.0.0.1:389")
7 results = connection.search_s(dn, ldap.SCOPE_SUBTREE, ldapQuery)
8
9 return results
```

В этом примере злоумышленник может манипулировать и значением dn, и самим запросом.

Если передать в переменную `jediTypeRequest` строку, которая сначала завершит формирование фильтра, а затем, с помощью специального символа, добавит к нему команду, то эта команда выполнится. Например, если передать значение `"Evilson, Evil)(|(objectclass=*))"`, то в итоге злоумышленник получит все записи в данном dn.

Как исправить?

Лучший способ - использовать белые списки. Белый список - это конечный список всех значений, которые вы, как разработчик, считаете легитимными для использования программой. Например, вы точно знаете, к каким разделам каталога будет делаться запрос. Тогда вы можете составить список этих dn и проверять входные параметры на наличие в этом списке.

Пример безопасного кода

```
1 whitelist_dn = ('dn1', 'dn2', 'dn3')
2 whitelist_filter = ('value1', 'value2', 'value3')
3
4 dn = params.Get['dn']
5 jediTypeRequest = params.Get['jediType']
```

```
6
7 if dn in whitelist_dn and jediTypeRequest in whitelist_filter:
8     ldapQuery = f"(|(jediType={jediTypeRequest})(&(cloneWars=yes)
    (alive=yes)))"
9     connection = ldap.initialize("ldap://127.0.0.1:389")
10    results = connection.search_s(dn, ldap.SCOPE_SUBTREE, ldapQuery)
```

Альтернативные способы

Если вы не можете использовать белый список (например, он получается бесконечно большим), то необходимо фильтровать специальные символы.

Для dn это следующие символы: \ # + < > , ; " =

Для самого запроса: * () \ NUL

Полезные ссылки

[Как защищаться от LDAP-инъекций в OWASP](#)